

Talent-X

Document 7 — Analyse d'impact relative à la protection des données (AIPD / DPIA)

Projet d'analyse structuré selon la méthode CNIL/EDPB — à compléter et valider par le DPO.

Référence	TX-DPIA-007
Version	1.0 (projet)
Date	4 juin 2026
Statut	Projet d'analyse d'impact (AIPD) — à compléter et valider par le DPO ou un conseil juridique

Avertissement essentiel. Ce document est un projet d'analyse d'impact relative à la protection des données (AIPD / DPIA) destiné à structurer et accélérer l'analyse à partir du lot documentaire Talent-X. Il ne constitue pas un avis juridique et n'a pas valeur d'AIPD validée. Il doit être complété, vérifié et formellement validé par un DPO ou un conseil juridique compétent, qui rend l'avis prévu à l'article 35(2) et statue sur la mise en production. Les appréciations de gravité, de vraisemblance et de risque résiduel ci-dessous sont des propositions à valider.

Historique des révisions

Version	Date	Nature des modifications
1.0 (projet)	4 juin 2026	Projet initial, structuré selon la démarche CNIL/EDPB, à partir du lot Talent-X (TX-ARCH-001, TX-SPEC-002, TX-SEC-003, TX-DATA-006, TX-OPS-004). Sections d'avis et de décision à compléter par le DPO.

Sommaire

Historique des révisions	2
1. Objet et méthode	3
2. Description du traitement	3
2.1 Finalités	3
2.2 Données et personnes concernées	3
2.3 Acteurs	3
2.4 Flux et cycle de vie des données	4
2.5 Supports (actifs)	4
3. Nécessité et proportionnalité	4
3.1 Bases juridiques	4
3.2 Minimisation	4
3.3 Qualité et exactitude	4
3.4 Durées de conservation	4
3.5 Information et transparence	4
4. Mesures protégeant les droits des personnes	5
5. Appréciation des risques	5
5.1 Accès illégitime aux données (confidentialité)	5
5.2 Modification non désirée des données (intégrité)	6
5.3 Disparition des données (disponibilité)	6
5.4 Points d'attention spécifiques	6
6. Plan d'action et risques résiduels	7
7. Avis et validation	7
8. Conclusion	7

1. Objet et méthode

Pourquoi cette analyse. Le traitement de suivi de performance sportive de Talent-X porte sur des données pouvant permettre d'inférer la santé (art. 9 du RGPD), de façon systématique et à grande échelle (suivi régulier d'athlètes). À ce titre, une analyse d'impact est probablement requise au sens de l'article 35. Son caractère obligatoire est à confirmer par le DPO.

Méthode. Le document suit la démarche en quatre temps de la CNIL, alignée sur les lignes directrices de l'EDPB : description du traitement (contexte), évaluation de la nécessité et de la proportionnalité, mesures protégeant les droits des personnes, appréciation des risques de sécurité, puis plan d'action et validation.

Périmètre. Le traitement principal « suivi de performance sportive » et les traitements associés : gestion des comptes, collaboration coach-athlète, notifications et exercice des droits. L'analyse s'appuie sur le lot documentaire Talent-X et n'en reprend pas le détail technique.

Référentiels mobilisés :

- Article 35 du RGPD (analyse d'impact relative à la protection des données).
- Lignes directrices de l'EDPB sur l'AIPD (WP248 rév.01).
- Guide et logiciel PIA de la CNIL (démarche et échelles de cotation).

2. Description du traitement

2.1 Finalités

- Organiser et diffuser des séances d'entraînement.
- Enregistrer et suivre les performances et la progression.
- Permettre au coach d'accompagner l'athlète (feedback, suivi).
- Faciliter la collaboration et la structuration en groupes.
- Notifier les utilisateurs des événements pertinents.

2.2 Données et personnes concernées

Catégories de données	Identité, authentification, profil sportif, performances, identifiants d'appareil, logs, exports/sauvegardes (détail en TX-SEC-003 §3).
Personnes concernées	Coachs et athlètes. Mineurs potentiellement concernés (sport jeunes) — périmètre à trancher (TX-SEC-003 §7).
Données sensibles (art. 9)	Les performances (charges, RPE, ressenti, paramètres corporels) peuvent permettre d'inférer la santé : traitées comme données sensibles.

2.3 Acteurs

Responsable de traitement	L'exploitant de Talent-X (personne physique ou morale).
Sous-traitants	OVHcloud (hébergement, UE), fournisseur SMTP, Apple (APNs), Google (FCM). Registre en TX-SEC-003 §17.

2.4 Flux et cycle de vie des données

- Collecte via l'application mobile (saisie de séances et de performances).
- Traitement par l'API et le worker (validation, calculs, notifications, exports).
- Conservation dans PostgreSQL selon des durées bornées (TX-SEC-003 §9).
- Exercice des droits : export structuré et effacement asynchrones (TX-SPEC-002, TX-SEC-003).
- Sauvegardes chiffrées (fenêtre roulante de 30 jours) ; effacement réel jusqu'à ce délai.
- Transfert sortant des notifications vers APNs/FCM, hors UE (TX-SEC-003 §10).

2.5 Supports (actifs)

Application mobile (React Native/Expo), API NestJS, worker, PostgreSQL, Redis, stockage objet, hébergement OVHcloud (UE), services tiers APNs/FCM/SMTP. La vue d'architecture (C4) figure dans TX-ARCH-001.

3. Nécessité et proportionnalité

3.1 Bases juridiques

- Compte et fourniture du service : exécution du contrat (art. 6(1)(b)).
- Données de performance sensibles : consentement explicite (art. 9(2)(a)), séparé, tracé et révocable.
- Sécurité et journalisation : intérêt légitime, avec minimisation.

3.2 Minimisation

- Ne collecter que les données nécessaires aux finalités ; pas d'analytics intrusif au MVP.
- Contenu des notifications push minimal : aucun résultat de performance ou donnée de santé dans le corps de la notification.

3.3 Qualité et exactitude

Édition du profil par l'utilisateur ; correction tracée de l'historique sans modification silencieuse (RB-06) ; droit de rectification opérationnalisé (TX-SEC-003 §8).

3.4 Durées de conservation

Durées bornées par catégorie (TX-SEC-003 §9) : compte actif, performances limitées dans le temps, logs 90 jours, sauvegardes 30 jours, exports 7 jours. Le délai réel d'effacement (jusqu'à 30 jours) est annoncé dans la politique de confidentialité.

3.5 Information et transparence

Politique de confidentialité et écrans d'onboarding ; registre des traitements tenu (art. 30, TX-SEC-003 §5).

4. Mesures protégeant les droits des personnes

Droit	Mesure	Réf.
Information	Politique de confidentialité et écrans d'onboarding	SEC §8
Consentement	Écran dédié sans case pré-cochée ; retrait à tout moment ; « accès coach » conditionnant l'accès (RB-08)	SEC §6
Accès	Consultation in-app et export des données	SPEC §8.2
Rectification	Édition du profil ; correction tracée de l'historique	RB-06
Effacement	Suppression de compte (asynchrone) puis purge	SEC §9.2
Portabilité	Export structuré et réutilisable	SEC §9.1
Limitation	Procédure de gel du traitement sur demande	SEC §8
Opposition	Retrait de consentement et opposition aux traitements concernés	SEC §6

Sous-traitants et transferts : accords de sous-traitance (art. 28) à signer ; transferts hors UE (push) encadrés et minimisés, mécanisme à vérifier (TX-SEC-003 §10 et §17).

5. Appréciation des risques

Les risques de sécurité sont évalués selon la méthode des trois événements redoutés (CNIL), cotés en gravité et en vraisemblance sur une échelle à quatre niveaux. Les cotations ci-dessous sont des propositions à valider par le DPO.

Niveau	Lecture indicative
Négligeable	Les personnes ne seront pas impactées ou de façon négligeable.
Limité	Désagréments surmontables (effort, stress).
Important	Conséquences significatives et difficiles à surmonter.
Maximal	Conséquences graves, potentiellement irréversibles.

5.1 Accès illégitime aux données (confidentialité)

Événement redouté	Divulgaration de données de performance pouvant inférer la santé.
Sources de risque	Attaquant externe, sous-traitant, erreur interne.
Principales menaces	Vol de jeton, injection, escalade, accès du coach sans consentement, fuite via logs, compromission d'un export, transfert hors UE non maîtrisé.
Impacts pour les personnes	Atteinte à la vie privée, inférence de santé, stigmatisation.
Gravité (proposée)	Importante (données pouvant inférer la santé).
Vraisemblance (proposée)	Limitée, compte tenu des mesures.
Mesures en place ou prévues	TLS 1.3 et chiffrement au repos ; RBAC + appartenance + ownership + consentement (RB-08) ; rotation et détection de réutilisation des jetons ; reset anti-énumération ; redaction des

	logs ; exports chiffrés à durée de vie courte ; minimisation du contenu des push.
Risque résiduel (proposé)	Limité — à valider.

5.2 Modification non désirée des données (intégrité)

Événement redouté	Altération non autorisée de performances ou de l'historique.
Sources de risque	Utilisateur malveillant, défaut applicatif, escalade de privilèges.
Principales menaces	Écriture non autorisée, perte d'intégrité, doublons.
Impacts pour les personnes	Décisions d'entraînement faussées, perte de confiance.
Gravité (proposée)	Limitée.
Vraisemblance (proposée)	Limitée.
Mesures en place ou prévues	Contraintes d'intégrité en base (TX-DATA-006) ; journal d'audit et historique non modifiable sans trace (RB-06) ; correction tracée ; autorisation par guards ; idempotence des écritures.
Risque résiduel (proposé)	Limité à négligeable — à valider.

5.3 Disparition des données (disponibilité)

Événement redouté	Perte de données ou indisponibilité du service.
Sources de risque	Panne, incident d'hébergement, suppression accidentelle.
Principales menaces	Perte de volume, sinistre, corruption.
Impacts pour les personnes	Perte de l'historique, interruption du suivi.
Gravité (proposée)	Limitée.
Vraisemblance (proposée)	Limitée.
Mesures en place ou prévues	Sauvegardes chiffrées hors nœud et clés conservées hors nœud ; tests de restauration ; PRA/PCA ; monitoring (TX-OPS-004 §8).
Risque résiduel (proposé)	Négligeable à limité — à valider.

5.4 Points d'attention spécifiques

- Mineurs : si le périmètre inclut des mineurs, la gravité des événements redoutés augmente et des mesures dédiées sont requises (vérification d'âge, consentement parental) — décision à trancher (TX-SEC-003 §7).
- Transferts hors UE (push) : risque de conformité à lever par la vérification du mécanisme de transfert et la minimisation du contenu des notifications (TX-SEC-003 §10).

6. Plan d'action et risques résiduels

Action	Priorité	Réf.	Statut
Faire valider l'AIPD et recueillir l'avis du DPO (art. 35(2))	Haute	§7	À faire
Trancher la place des mineurs (art. 8)	Haute	SEC §7	À décider
Vérifier le mécanisme de transfert APNs/FCM et minimiser les push	Haute	SEC §10	À faire
Signer les accords de sous-traitance (art. 28)	Haute	SEC §17	À faire
Définir le périmètre du chiffrement applicatif de champs	Moyenne	SEC §12	À décider
Confirmer les durées de conservation et le délai d'effacement	Moyenne	SEC §9	À confirmer
Mettre en place le registre des violations et la procédure 72 h	Moyenne	SEC §15	À faire
Désigner ou confirmer le DPO	Moyenne	SEC §2	À évaluer
Tester de bout en bout l'export et l'effacement	Moyenne	OPS §6	À faire

Sous réserve de la mise en œuvre du plan d'action et de la validation du DPO, le risque résiduel global est estimé acceptable (proposition à valider). Les deux points ouverts à plus fort enjeu sont la place des mineurs et l'encadrement des transferts hors UE.

7. Avis et validation

Section à compléter par le DPO et le responsable de traitement.

Avis du DPO	À compléter (art. 35(2)).
Avis des personnes concernées	À recueillir et documenter le cas échéant (art. 35(9)).
Décision sur la mise en production	À statuer par le responsable de traitement au vu du risque résiduel.
Prochaine revue	Date à fixer ; révision en cas de changement substantiel du traitement.

Événements déclenchant une nouvelle évaluation :

- Nouveau type de données ou nouvelle finalité.
- Extension du périmètre aux mineurs.
- Nouveau sous-traitant ou nouveau transfert hors UE.
- Incident de sécurité majeur ou violation de données.
- Évolution réglementaire significative.

8. Conclusion

Ce projet d'analyse d'impact montre que Talent-X intègre dès la conception des mesures proportionnées au caractère sensible des données traitées. Le risque principal — l'accès illégitime à des données pouvant inférer la santé — est réduit par des mesures techniques

et organisationnelles déjà spécifiées dans le lot documentaire : chiffrement, autorisation conditionnée au consentement, journalisation maîtrisée, minimisation des notifications et sauvegardes protégées.

La finalisation de l'AIPD passe par la validation du DPO, le recueil de son avis formel et le traitement des deux points ouverts à plus fort enjeu : la place des mineurs et l'encadrement des transferts hors UE. Le plan d'action de la section 6 en constitue la feuille de route.